

3-Splunk Basics - Did you SIEM

Introduction



Ya casi es Navidad en Wareville, y el equipo de The Best Festival Company (TBFC) está ocupado preparando la gran celebración. Todo marcha a la perfección hasta que el panel del SOC parpadea en rojo. De repente, aparece un mensaje de rescate:



El mensaje proviene del Rey Malhare, el celoso gobernante de la Isla HopSec, cansado de que se olvide la Pascua. Ha enviado a sus Conejitos Bandidos para atacar los sistemas de TBFC y convertir la Navidad en su nueva festividad, EAST-mas.

Con McSkidy desaparecido y la red bajo ataque, el equipo SOC de TBFC utilizará Splunk para determinar cómo se infiltró el ransomware en el sistema y evitar que el plan del Rey Malhare se vea comprometido antes de Navidad.

Objetivos de aprendizaje

- Ingerir e interpretar datos de registro personalizados en Splunk
- Crear y aplicar extracciones de campos personalizados
- Usar el Lenguaje de Procesamiento de Búsqueda (SPL) para filtrar y refinar los resultados de búsqueda
- Realizar una investigación en Splunk para descubrir información clave

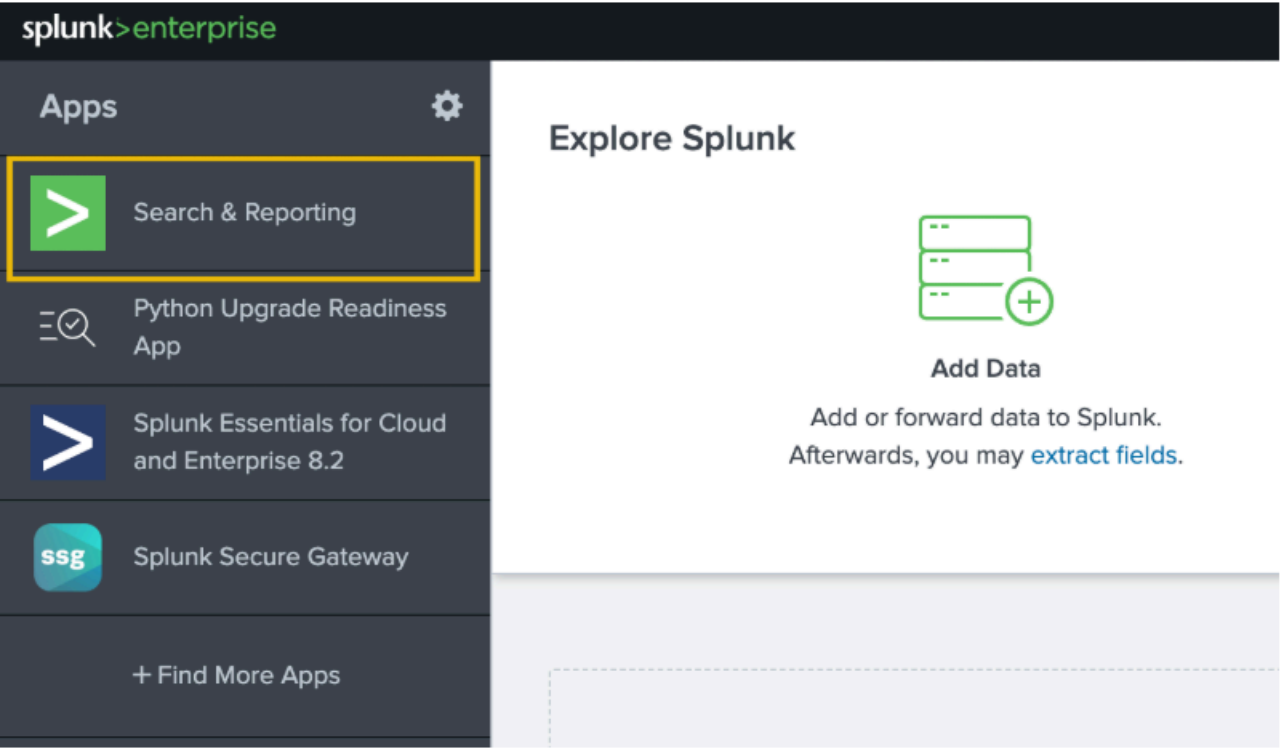
Inicie su máquina virtual haciendo clic en el botón "Iniciar máquina" que aparece a continuación. La máquina tardará entre 2 y 3 minutos en arrancar por completo. Una vez que la máquina esté en funcionamiento, puede conectarse al SIEM de Splunk visitando <https://10-66-144-211.reverse-proxy.cell-prod-us-east-1c.vm.tryhackme.com> en su navegador.

Nota: Si recibe un error 502 al acceder al enlace, espere un poco más para que la instancia de Splunk arranque por completo.

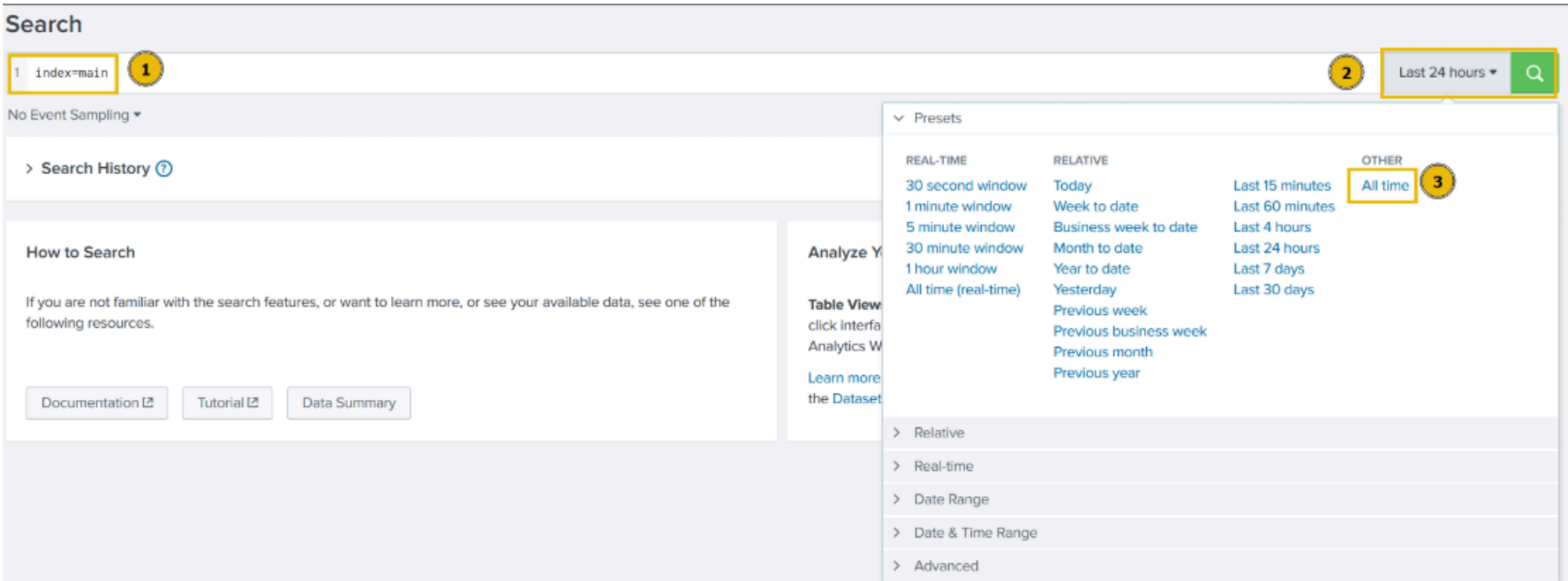
Log Analysis with Splunk

Exploración de los registros

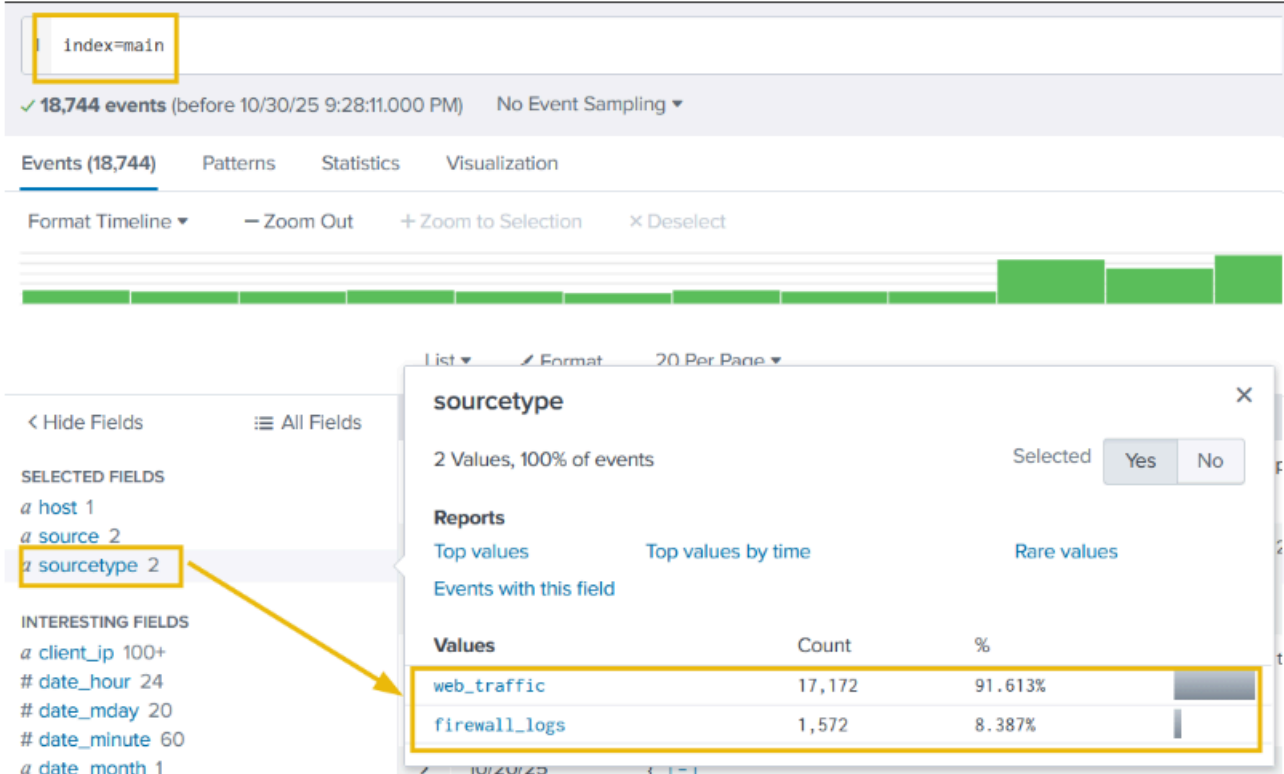
En la instancia de Splunk, los datos se han preingresado para que podamos investigar el incidente. En la interfaz de Splunk, haga clic en "Buscar e informes" en el panel izquierdo, como se muestra a continuación:



En la página siguiente, escriba `index=main` en la barra de búsqueda para ver todos los registros ingresados. Tenga en cuenta que debe seleccionar `All Time` como intervalo de tiempo en el menú desplegable a la derecha de la barra de búsqueda.



Tras ejecutar la consulta, se nos presentarán dos conjuntos de datos independientes preingeridos en Splunk. Podemos comprobarlo haciendo clic en el campo `sourcetype` en la lista de campos a la izquierda de la página.



Los dos conjuntos de datos son los siguientes:

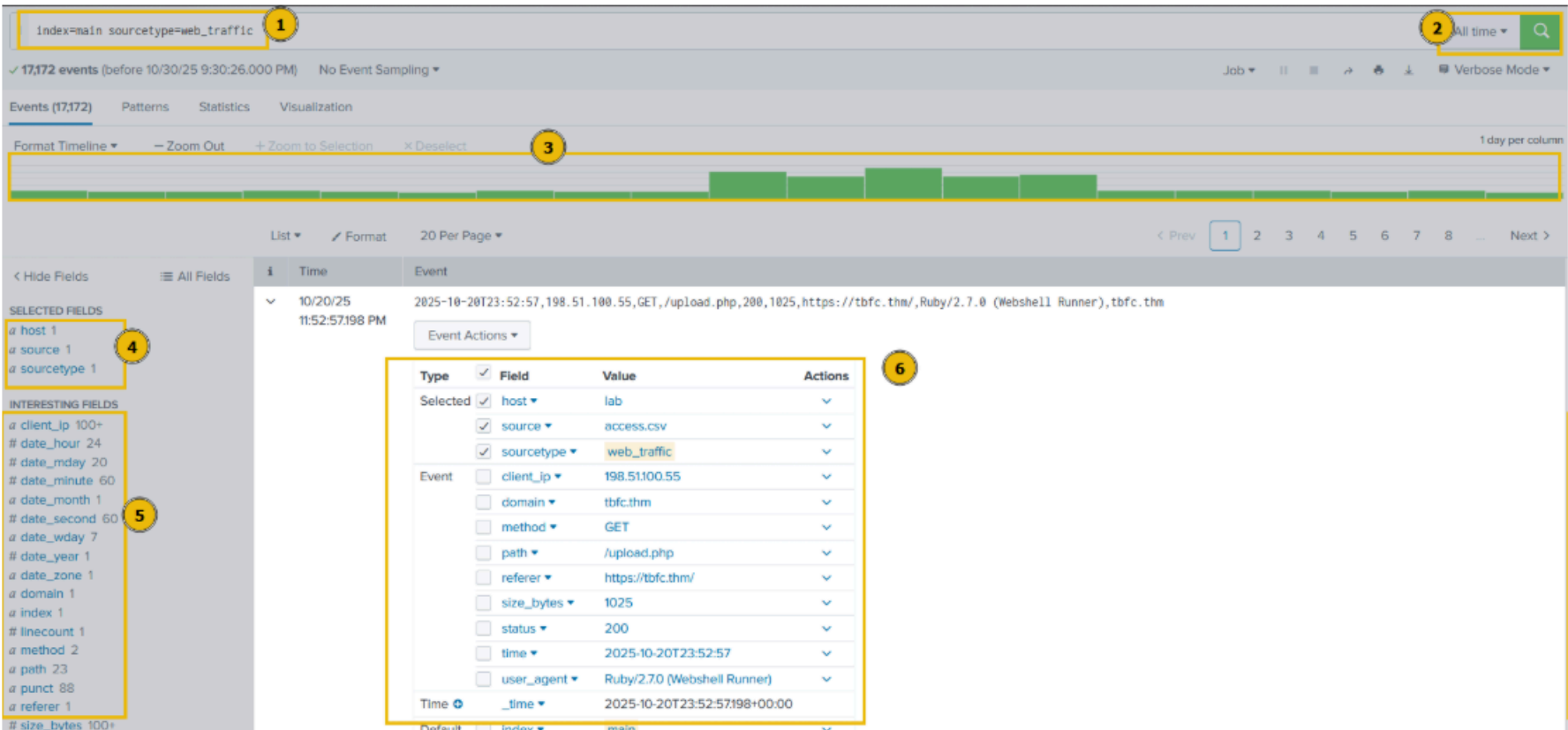
- **web_traffic:** Esta fuente de datos contiene eventos relacionados con las conexiones web hacia y desde el servidor web.
- **firewall_logs:** Esta fuente de datos contiene los registros del firewall, que muestran el tráfico permitido o bloqueado. La IP local asignada al servidor web es 10.10.1.15.

Analicemos los registros e investiguemos el ataque a nuestros servidores para identificar al responsable.

Triage inicial

Inicie una búsqueda básica en el índice utilizando su `sourcetype` personalizado `web_traffic`, con la siguiente consulta:

Consulta de búsqueda: `index=main sourcetype=web_traffic`



Analicemos nuestro resultado para una mejor comprensión:

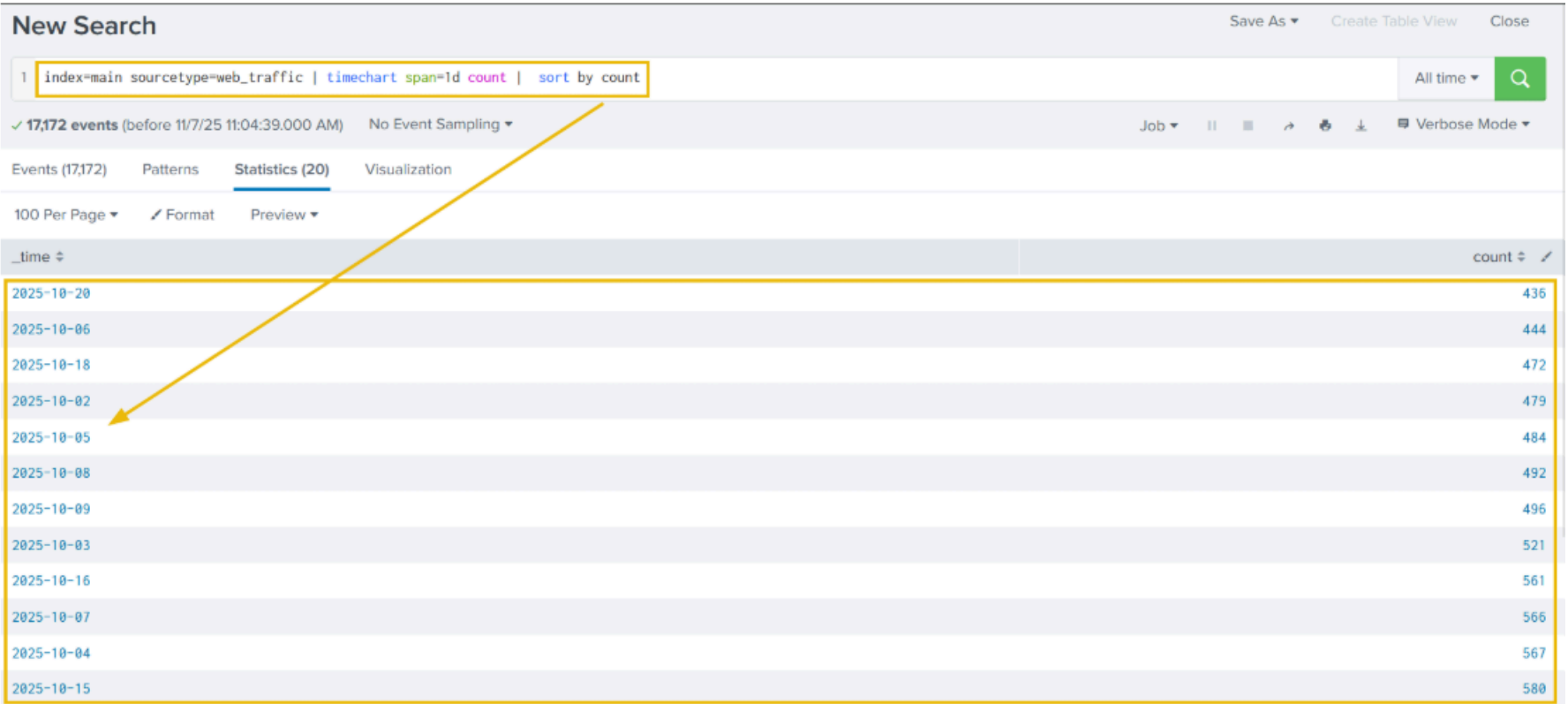
- Consulta de búsqueda (search query):** Esta consulta recupera todos los eventos del índice `main` etiquetados con el `sourcetype` personalizado `web_traffic`. Esto marca el inicio de la investigación.
- Intervalo de tiempo (time range):** El intervalo de tiempo está configurado actualmente como "All Time". En el análisis de seguridad, este intervalo se ajustaría (por ejemplo, a la ventana de pico) después de la carga inicial de datos.
- Cronología (timeline):** Este histograma visual muestra la distribución de los 17,172 eventos a lo largo del tiempo. El gráfico indica el volumen de registro diario exitoso, seguido de un pico de tráfico distintivo (un período de alta actividad, probablemente la ventana de ataque).
- Campos seleccionados (selected fields):** Estos son los campos seleccionados actualmente para mostrarse en la columna de resumen de la lista de eventos (`host`, `source`, `sourcetype`). Representan metadatos básicos sobre el archivo de registro.
- Campos de interés (interesting fields):** Este panel enumera todos los campos que Splunk ha extraído o añadido manualmente automáticamente. Los campos con el prefijo `#` (por ejemplo, `#Date_hour`) se generan automáticamente mediante los comandos de tiempo de Splunk. La presencia de `user_agent`, `path` y `client_ip` confirma el análisis correcto de la estructura del registro web.
- Detalles del evento y extracción de campos:** Esta sección muestra los detalles analizados de un solo evento con campos extraídos como `user_agent`, `path`, `status`, `client_ip` y más.

Ahora que comprendemos el diseño de Splunk y cómo leer los registros, continuemos con el análisis de los registros.

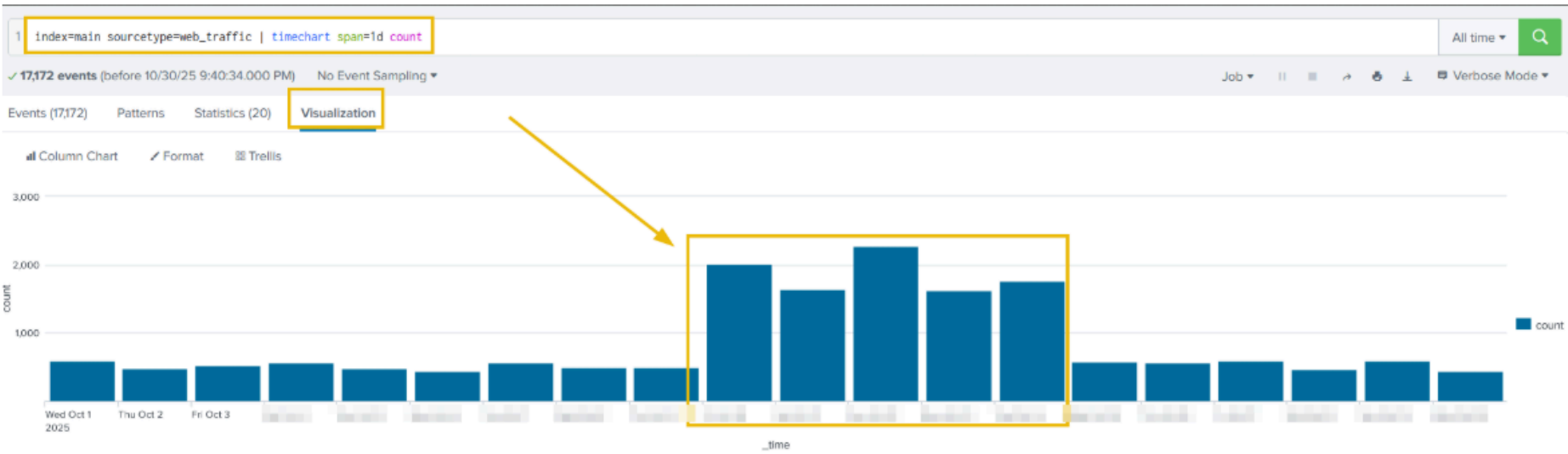
Visualización de la cronología de registros

Grafiquemos el recuento total de eventos a lo largo del tiempo, agrupados por día, para determinar la cantidad de eventos capturados por día. Esto nos ayudará a identificar el día en que recibió una cantidad anormal de registros.

Consulta de búsqueda: `index=main sourcetype=web_traffic | timechart span=1d count` | `sort by count`



Los resultados anteriores muestran ahora los registros de eventos capturados por día. Esto podría ser interesante, ya que algunos días se registra un gran volumen de registros. También podemos hacer clic en la pestaña `Visualization` para examinar el gráfico y obtener una mejor representación, como se muestra a continuación:



Podemos añadir la función `reverse` al final para mostrar el resultado en orden descendente, mostrando el día con el mayor número de eventos al principio.

Consulta de búsqueda: `index=main sourcetype=web_traffic | timechart span=1d count | sort by count | reverse`

The screenshot shows a Splunk search interface with the query: `index=main sourcetype=web_traffic | timechart span=1d count | sort by count | reverse`. The results show 17,172 events. The 'Statistics' tab is selected, displaying a table of results. The table has two columns: `_time` and `count`. The results are sorted by count in descending order. A yellow box highlights the top 10 rows of the table.

_time	count
2025-10-10	2012
2025-10-14	1755
2025-10-11	1637
2025-10-13	1617
2025-10-17	596
2025-10-19	595
2025-10-01	595
2025-10-15	580
2025-10-04	567
2025-10-07	566
2025-10-16	561
2025-10-03	521
2025-10-09	496

Hay un período claro de intensa actividad durante el cual el Rey Malhare lanzó su fase principal de ataque.

Detección de Anomalías

Ahora que hemos examinado los días con registros anormales, usando la tabla y el gráfico, usemos la misma consulta de búsqueda para examinar varios campos y buscar valores sospechosos. Necesitamos regresar a la pestaña Eventos para continuar.

User_Agent

Hagamos clic en el campo `user_agent` en el panel izquierdo, como se muestra a continuación. Nos mostrará los detalles sobre los agentes de usuario capturados hasta el momento.

The screenshot shows a Splunk search interface with the query: `index=main sourcetype=web_traffic | timechart span=1d count | sort by count | reverse`. The results show 17,172 events. The 'Statistics' tab is selected, displaying a table of results. The table has two columns: `_time` and `count`. The results are sorted by count in descending order. A yellow box highlights the top 10 rows of the table. An arrow points from the 'user_agent' field in the left sidebar to the highlighted table.

user_agent	Count	%
Mozilla/5.0 (iPhone; CPU iPhone OS 17_5 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Mobile/15E148 Safari/604.1	3,160	18.402%
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36	3,075	17.907%
Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.4 Safari/605.1.15	3,061	17.826%
Wget/1.21.4	1,240	7.221%
zgrab/0.x	1,238	7.209%
curl/7.88.1	1,220	7.104%
Go-http-client/1.1	1,201	6.994%
Havij/1.17 (Automated SQL Injection)	967	5.783%
sqlmap/1.7.9#stable (http://sqlmap.org)	967	5.631%
python-requests/2.28.1	510	2.97%

Tras un análisis más detallado, queda claro que, además de los agentes de usuario legítimos, como las variantes de Mozilla, recibimos una gran cantidad de agentes sospechosos, que debemos investigar más a fondo.

client_ip

El segundo campo que examinaremos es `client_ip`, que contiene las direcciones IP de los clientes que acceden al servidor web. Inmediatamente, destaca una dirección IP en particular, que investigaremos más a fondo.

< Hide Fields

≡ All Fields

SELECTED FIELDS

z host 1

z source 1

z sourcetype 1

INTERESTING FIELDS

client_ip 100+

date_hour 24

date_mday 20

date_minute 60

z date_month 1

date_second 60

z date_wday 7

date_year 1

z date_zone 1

z domain 1

z index 1

linecount 1

z method 2

client_ip

>100 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

Count

%

192.168.121.337,87645.865%

192.168.185.18130.017%

192.168.239.12730.017%

192.168.244.22830.017%

192.168.3.11830.017%

192.168.81.7030.017%

192.168.12.16620.012%

192.168.126.420.012%

192.168.128.6620.012%

path

El tercer campo que examinaremos es la ruta, que contiene la URI solicitada y a la que acceden las IP del cliente. Los resultados que se muestran a continuación indican claramente algunos ataques que merecen la pena investigar.

a client_ip 100+

date_hour 24

date_mday 20

date_minute 60

a date_month 1

date_second 60

a date_wday 7

date_year 1

a date_zone 1

a domain 1

a index 1

linecount 1

a method 2

z path 23

a punct 88

a referer 1

size_bytes 100+

a splunk_server 1

status 7

a time 100+

timeendpos 1

timestartpos 1

a user_agent 11

+ Extract New Fields

> 10/20/252025-10-20T23:47:36,192.168.59.91,POST,/index.html,304,3093,f

path

23 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

Count

%

/index.html1,5819.207%

/blog1,5679.125%

/1,5659.114%

/static/app.css1,5328.922%

/shop1,5268.886%

/contact1,5258.881%

/search?q=test6663.878%

/item.php?id=16613.849%

/item.php?id=1 AND SLEEP(5)--6603.843%

/download?file=../../etc/passwd3.832%

Filtrando valores benignos

Sabemos que los conejos del Rey Malhare usan scripts y herramientas, no navegadores estándar. Filtraremos todo el tráfico estándar.

Excluiremos los agentes de usuario legítimos comunes. La siguiente consulta eliminará los agentes de usuario legítimos de los resultados y solo mostrará los sospechosos, que investigaremos más a fondo.

Consulta de búsqueda: index=main sourcetype=web_traffic user_agent!=*Mozilla* user_agent!=*Chrome* user_agent!=*Safari* user_agent!=*Firefox*

1Index=main sourcetype=web_traffic user_agent!=*Mozilla* user_agent!=*Chrome* user_agent!=*Safari* user_agent!=*Firefox*

7,876 events (before 10/30/25 10:17:51.000 PM)No Event Sampling

Events (7,876)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect

< Hide Fields

≡ All Fields

SELECTED FIELDS

a host 1

a source 1

a sourcetype 1

INTERESTING FIELDS

a client_ip 1

date_hour 24

date_mday 20

date_minute 60

a date_month 1

date_second 60

a date_wday 7

date_year 1

a date_zone 1

a domain 1

a index 1

linecount 1

a method 2

a path 17

a punct 70

a referer 1

client_ip

1 Value, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values

Count

%

192.168.59.917,876100%

> 10/20/252025-10-20T23:52:57.198.51.100.55.GET,/upload.php,403,2557,https://tbfc.thm/,Ruby/2.7.0 (WebsHELL Runner),tbfc.thm

10:48:06.198 PMhost = labsource = access.csvsourcetype = web_traffic

> 10/20/252025-10-20T22:33:54.198.51.100.55.POST,/server-status,403,3065,,curl/7.88.1,tbfc.thm

10:33:54.198 PMhost = labsource = access.csvsourcetype = web_traffic

> 10/20/252025-10-20T22:29:45.198.51.100.55.GET,/upload.php,403,2419,,Ruby/2.7.0 (WebsHELL Runner),tbfc.thm

10:29:45.198 PMhost = labsource = access.csvsourcetype = web_traffic

El resultado revela resultados interesantes. Al hacer clic en el campo client_ip , podemos ver que una única dirección IP es responsable de todos los agentes de usuario sospechosos. Anotemos esto para una investigación más profunda y completemos las secciones <REDACTED> de las próximas consultas con esa IP.

Delimitando las IP sospechosas

En situaciones reales, a menudo nos encontramos con varias direcciones IP que intentan atacar constantemente nuestros servidores. Para delimitar las direcciones IP que no envían solicitudes desde navegadores comunes de escritorio o móviles, podemos usar la siguiente consulta:

Consulta de búsqueda: sourcetype=web_traffic user_agent!=*Mozilla* user_agent!=*Chrome* user_agent!=*Safari* user_agent!=*Firefox* | stats count by client_ip | sort -count | head 5

New Search

Save AsCreate Table ViewClose

1 sourcetype=web_traffic user_agent!=*Mozilla* user_agent!=*Chrome* user_agent!=*Safari* user_agent!=*Firefox* | stats count by client_ip | sort -count | head 5

All time

7,876 events (before 10/30/25 10:19:52.000 PM)No Event Sampling

JobPauseFilterExportImportDownloadVerbose Mode

Events (7,876)PatternsStatistics (1)Visualization

100 Per PageFormatPreview

client_ipcount7876

El resultado confirma la IP principal utilizada por los Bandit Bunnies. En la consulta de búsqueda, el "-" en la parte "sort -count" ordenará el resultado por conteo en orden inverso; es lo mismo que usar la función "reverse". Seleccionemos esta dirección IP y filtrémosla para ver las huellas de las actividades capturadas.

Rastreando la cadena de ataque

Ahora nos centraremos en la IP del atacante seleccionado para rastrear sus pasos cronológicamente, confirmando el uso de múltiples herramientas y cargas útiles. No olvide reemplazar <REDACTED> con la IP que anotamos anteriormente.

Reconocimiento (Footprinting)

Comenzaremos la búsqueda del sondeo inicial de los archivos de configuración expuestos utilizando la siguiente consulta:

Consulta de búsqueda: sourcetype=web_traffic client_ip="<REDACTED>" AND path IN ("/.env", "/*phpinfo*", "/*git*") | table _time, path, user_agent, status

1 sourcetype=web_traffic client_ip="<REDACTED>" AND path IN ("/.env", "/*phpinfo*", "/*git*") | table _time, path, user_agent, status

All time

1,444 events (before 10/30/25 10:22:24.000 PM)No Event Sampling

JobPauseFilterExportImportDownloadVerbose Mode

Events (1,444)PatternsStatistics (1,444)Visualization

100 Per PageFormatPreview

_time	path	user_agent	status
2025-10-20 23:04:08.198	/.git/config	curl/7.88.1	403
2025-10-20 22:48:06.198	/phpinfo.php	curl/7.88.1	403
2025-10-20 21:33:28.198	/.env	curl/7.88.1	404
2025-10-20 19:15:59.198	/phpinfo.php	curl/7.88.1	403
2025-10-20 18:12:55.198	/.env	Go-http-client/1.1	403
2025-10-20 17:20:22.198	/phpinfo.php	Go-http-client/1.1	401
2025-10-20 16:53:18.198	/.env	Go-http-client/1.1	401
2025-10-20 15:33:11.198	/.git/config	zgrab/0.x	404
2025-10-20 15:25:54.198	/.git/config	curl/7.88.1	401
2025-10-20 14:46:11.198	/phpinfo.php	zgrab/0.x	401
2025-10-20 14:00:51.198	/phpinfo.php	zgrab/0.x	404
2025-10-20 13:42:39.198	/.git/config	Go-http-client/1.1	403
2025-10-20 13:37:30.198	/.env	Wget/1.21.4	404
2025-10-20 13:24:04.198	/phpinfo.php	Wget/1.21.4	404

El resultado confirma que el atacante utilizó herramientas de bajo nivel (curl, wget) y se encontró con códigos de estado 404/403/401.

Enumeración (Prueba de vulnerabilidades)

Búsqueda de vulnerabilidades comunes de cruce de rutas y redireccionamiento abierto.

Consulta de búsqueda: sourcetype=web_traffic client_ip="<REDACTED>" AND path="*.*.*" OR path="*redirect*"

1 sourcetype=web_traffic client_ip="<REDACTED>" AND path="*.*.*" OR path="*redirect*"div>All time

1,291 events (before 12/3/25 5:55:51.000 AM)No Event Sampling

JobPauseFilterExportImportDownloadVerbose Mode

Events (1,291)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect1 day per column

Hide FieldsAll Fields

SELECTED FIELDS

host1# source1# sourcetype1

INTERESTING FIELDS

client_ip1# date_hour24# date_mday20# date_minute60# date_month1# date_second60# date_wday7# date_year1# date_zone1# domain1

#	Time	Event
>	10/20/25 10:23:05.198 PM	2025-10-20T22:23:05.198Z,POST,/download?file=../../etc/passwd,200,1881,https://tbfc.thm/,curl/7.88.1,tbfc.thm host = lab source = access.csv sourcetype = web_traffic
>	10/20/25 9:34:46.198 PM	2025-10-20T21:34:46.198Z,POST,/download?file=../../etc/passwd,200,1046,https://tbfc.thm/,Wget/1.21.4,tbfc.thm host = lab source = access.csv sourcetype = web_traffic
>	10/20/25 9:17:26.198 PM	2025-10-20T21:17:26.198Z,GET,/download?file=../../etc/passwd,500,3374,,curl/7.88.1,tbfc.thm host = lab source = access.csv sourcetype = web_traffic
>	10/20/25 9:13:14.198 PM	2025-10-20T21:13:14.198Z,POST,/redirect=http://evil.site,403,1119,https://tbfc.thm/,Wget/1.21.4,tbfc.thm host = lab source = access.csv sourcetype = web_traffic
>	10/20/25 8:21:07.198 PM	2025-10-20T20:21:07.198Z,GET,/redirect=http://evil.site,200,1150,https://tbfc.thm/,Wget/1.21.4,tbfc.thm host = lab source = access.csv sourcetype = web_traffic
>	10/20/25 7:45:20.198 PM	2025-10-20T19:45:20.198Z,GET,/download?file=../../etc/passwd,500,953,,Wget/1.21.4,tbfc.thm host = lab source = access.csv sourcetype = web_traffic

El resultado muestra los recursos a los que el atacante intenta acceder. Actualicemos la consulta de búsqueda para obtener el recuento de recursos solicitados por el atacante. Esta consulta filtra las rutas que contienen ../../ o el término "redirect", como se muestra a continuación. Esto se hace para buscar rastros de intentos de atravesar la ruta (../../). Para ello, debemos actualizar la consulta de búsqueda para escapar caracteres como ../../.

Consulta de búsqueda: sourcetype=web_traffic client_ip="<REDACTED>" AND path="*.*.*" OR path="*redirect*" | stats count by path

New Search

Save AsCreate Table ViewClose

1

sourcetype=web_traffic client_ip=[REDACTED] AND path=*.\\.* OR path=*redirect* | stats count by path

All time

Q

✓ 1,291 events (before 11/7/25 11:57:08.000 AM) No Event SamplingJobPauseResetDownloadVerbose Mode

Events (1,291)PatternsStatistics (2)Visualization

100 Per PageFormatPreview

path

count

/?redirect=http://evil.site633

/download?file=../../etc/passwd

Resultados bastante interesantes. Revela intentos de lectura de archivos del sistema (.././.*), lo que demuestra que el atacante pasó del simple escaneo a realizar pruebas de vulnerabilidad activas.

Ataque de inyección SQL

Encuentre la herramienta de ataque automatizada y su carga útil mediante la siguiente consulta:

Consulta de búsqueda: sourcetype=web_traffic client_ip="[REDACTED]" AND user_agent IN ("*sqlmap*", "*Havij*") | table _time, path, status

New Search

Save AsCreate Table ViewClose

1

sourcetype=web_traffic client_ip=[REDACTED] AND user_agent IN (*sqlmap*, *Havij*) | table _time, path, status

All time

Q

✓ 1,960 events (before 11/7/25 11:58:23.000 AM) No Event SamplingJobPauseResetDownloadVerbose Mode

Events (1,960)PatternsStatistics (1,960)Visualization

100 Per PageFormatPreview

< Prev

1

2

3

4

5

6

7

8

...

Next >

_time

path

status

2025-10-20 23:42:07.198/item.php?id=1500

2025-10-20 22:52:47.198/item.php?id=1 AND SLEEP(5)--500

2025-10-20 21:51:35.198/search.php?q=test'%20AND%20SLEEP(5)--504

2025-10-20 21:27:13.198/item.php?id=1 AND SLEEP(5)--200

2025-10-20 21:04:21.198/item.php?id=1 AND SLEEP(5)--500

2025-10-20 20:40:26.198/item.php?id=1 AND SLEEP(5)--200

2025-10-20 20:17:29.198/search.php?q=test'%20AND%20SLEEP(5)--504

2025-10-20 19:23:09.198/search.php?q=test'%20AND%20SLEEP(5)--200

2025-10-20 19:09:58.198/item.php?id=1200

2025-10-20 19:07:05.198/search.php?q=test'%20AND%20SLEEP(5)--504

2025-10-20 19:01:38.198/search.php?q=test'%20AND%20SLEEP(5)--500

Los resultados anteriores confirman el uso de inyecciones SQL conocidas y cadenas de ataque específicas como SLEEP(5). Un código de estado 504 suele confirmar un ataque de inyección SQL basado en tiempo exitoso.

Intentos de exfiltración

Buscar intentos de descarga de archivos grandes y sensibles (copias de seguridad, registros). Podemos usar la siguiente consulta:

Consulta de búsqueda: sourcetype=web_traffic client_ip="[REDACTED]" AND path IN ("*backup.zip*", "*logs.tar.gz*") | table _time path, user_agent

sourcetype=web_traffic client_ip=[REDACTED] AND path IN (*backup.zip*, *logs.tar.gz*) | table _time path, user_agent

✓ 347 events (before 10/30/25 10:54:52.000 PM) No Event SamplingJobPauseResetDownloadVerbose Mode

Events (347)PatternsStatistics (347)Visualization

100 Per PageFormatPreview

_time

path

user_agent

2025-10-20 21:41:04.198/logs.tar.gzzgrab/0.x

2025-10-20 14:53:46.198/logs.tar.gzWget/1.21.4

2025-10-20 14:12:21.198/logs.tar.gzWget/1.21.4

2025-10-20 11:02:52.198/logs.tar.gzzgrab/0.x

2025-10-20 09:32:28.198/logs.tar.gzcurl/7.88.1

2025-10-20 03:20:55.198/logs.tar.gzzgrab/0.x

2025-10-20 02:33:42.198/logs.tar.gzcurl/7.88.1

2025-10-20 01:30:46.198/logs.tar.gzGo-http-client/1.1

2025-10-19 21:54:18.198/logs.tar.gzzgrab/0.x

2025-10-19 18:40:50.198/logs.tar.gzzgrab/0.x

2025-10-19 15:37:06.198/logs.tar.gzcurl/7.88.1

2025-10-19 15:23:29.198/logs.tar.gzWget/1.21.4

2025-10-19 10:07:26.198/logs.tar.gzGo-http-client/1.1

2025-10-19 09:38:39.198/logs.tar.gzGo-http-client/1.1

2025-10-19 08:15:34.198/logs.tar.gzGo-http-client/1.1

2025-10-19 05:09:24.198/logs.tar.gzcurl/7.88.1

Los resultados indican que el atacante estaba exfiltrando grandes fragmentos de archivos de registro comprimidos mediante herramientas como curl, zgrab, entre otras. Podemos confirmar los detalles de estas conexiones en los registros del firewall.

Ransomware Staging y RCE

Las solicitudes de archivos confidenciales como /logs.tar.gz y /config indican que el atacante está recopilando datos para una doble extorsión. En los registros, identificamos algunas solicitudes relacionadas con bunnylock y shell.php. Utilicemos la siguiente consulta para ver de qué se tratan estas consultas de búsqueda.

Consulta de búsqueda: sourcetype=web_traffic client_ip="[REDACTED]" AND path IN ("*bunnylock.bin*", "*shell.php?cmd=*") | table _time, path, user_agent, status

1 sourcetype=web_traffic client_ip=[REDACTED] AND path IN ("*bunnylock.bin*", "*shell.php?cmd=*")

2 | table _time, path, user_agent, status

1,092 events (before 10/30/25 10:56:48.000 PM) No Event Sampling

Events (1,092) Patterns Statistics (1,092) Visualization

100 Per Page Format Preview

< Prev 1 2 3 4 5 6 7 8 ... Next >

_time	path	user_agent	status
2025-10-20 19:32:47.198	/shell.php?cmd=whoami	Ruby/2.7.0 (Webshell Runner)	500
2025-10-20 16:31:24.198	/bunnylock.bin	zgrab/0.x	200
2025-10-20 16:29:12.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	500
2025-10-20 15:15:30.198	/bunnylock.bin	Wget/1.21.4	403
2025-10-20 13:18:54.198	/bunnylock.bin	zgrab/0.x	200
2025-10-20 12:58:47.198	/shell.php?cmd=./bunnylock.bin	Ruby/2.7.0 (Webshell Runner)	200
2025-10-20 11:46:32.198	/shell.php?cmd=./bunnylock.bin	Ruby/2.7.0 (Webshell Runner)	500
2025-10-20 11:31:28.198	/bunnylock.bin	Wget/1.21.4	200
2025-10-20 10:52:07.198	/shell.php?cmd=whoami	Ruby/2.7.0 (Webshell Runner)	200
2025-10-20 10:20:57.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	403
2025-10-20 09:20:21.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	500
2025-10-20 08:52:09.198	/bunnylock.bin	curl/7.88.1	200
2025-10-20 08:37:50.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	500
2025-10-20 08:32:19.198	/shell.php?cmd=chmod%20+x%20bunnylock.bin	python-requests/2.28.1	500

Los resultados anteriores confirman claramente un webshell exitoso. El atacante ha obtenido control total del servidor web y también puede ejecutar comandos. Este tipo de ataque se denomina Ejecución Remota de Código (RCE). La ejecución de `/shell.php?cmd=./bunnylock.bin` indica que se está ejecutando un programa similar a un ransomware en el servidor.

Correlación de la Comunicación C2 Saliente

Dirigimos la búsqueda a los `firewall_logs` utilizando la IP del Servidor Comprometido (10.10.1.5) como origen y la IP del atacante como destino.

Consulta de búsqueda: `sourcetype=firewall_logs src_ip="10.10.1.5" AND dest_ip="[REDACTED]" AND action="ALLOWED" | table _time, action, protocol, src_ip, dest_ip, dest_port, reason`

New Search

Save As>Create Table ViewClose

1 sourcetype=firewall_logs src_ip="10.10.1.5" AND dest_ip="[REDACTED]" AND action="ALLOWED" | table _time, action, protocol, src_ip, dest_ip, dest_port, reason

285 events (before 11/7/25 12:14:34.000 PM) No Event Sampling

Events (285) Patterns Statistics (285) Visualization

100 Per PageFormatPreview

< Prev 1 2 3 Next >

_time	action	protocol	src_ip	dest_ip	dest_port	reason
2025-10-20 12:59:10	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-20 10:52:20	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-20 06:57:40	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 20:04:15	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 19:03:43	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 15:46:43	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 15:34:31	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 15:34:22	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 13:55:32	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 13:20:27	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 11:30:21	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 11:21:24	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT
2025-10-19 08:47:03	ALLOWED	TCP	10.10.1.5	[REDACTED]	8080	C2_CONTACT

Esta consulta demuestra que el servidor estableció inmediatamente una conexión saliente con la IP C2 del atacante en el puerto `DEST_PORT` sospechoso. Los campos `ACTION=ALLOWED` y `REASON=C2_CONTACT` confirman que el canal de comunicación del malware estaba activo.

Volumen de datos exfiltrados

También podemos usar la función suma para calcular la suma de los bytes transferidos, utilizando el campo `bytes_transferred`, como se muestra a continuación:

Consulta de búsqueda: `sourcetype=firewall_logs src_ip="10.10.1.5" AND dest_ip="[REDACTED]" AND action="ALLOWED" | stats sum(bytes_transferred) by src_ip`

New Search

Save As>Create Table ViewClose

1 sourcetype=firewall_logs src_ip="10.10.1.5" AND dest_ip="[REDACTED]" AND action="ALLOWED" | stats sum(bytes_transferred) by src_ip

285 events (before 11/7/25 12:47:28.000 PM) No Event Sampling

Events (285) Patterns Statistics (1) Visualization

100 Per PageFormatPreview

src_ip	sum(bytes_transferred)
10.10.1.5	[REDACTED]

Los resultados muestran un gran volumen de datos transferidos desde el servidor web comprometido al servidor C2.

Conclusión

- Identidad encontrada:** El atacante se identificó mediante el mayor volumen de tráfico web malicioso procedente de la IP externa.
- Vector de intrusión:** El ataque siguió una clara progresión en los registros web `sourcetype=web_traffic`.
- Reconocimiento:** Se iniciaron sondeos mediante `cURL/Wget`, buscando archivos de configuración (`/.env`) y probando vulnerabilidades de cruce de rutas.
- Explotación:** El uso de agentes de usuario `SQLmap` y cargas útiles específicas (`SLEEP(5)`) confirmó la fase de explotación exitosa.
- Entrega de la carga útil:** La acción sobre el objetivo se estableció mediante la ejecución exitosa final del comando `cmd=./bunnylock.bin` a través del shell

web.

- **Confirmación C2:** La consulta a los registros del firewall (`sourcetype=firewall_logs`) demostró la actividad posterior a la explotación. El servidor interno comprometido (SRC_IP: 10.10.1.5) estableció una conexión C2 saliente a la IP del atacante.

Answer the questions below

What is the attacker IP found attacking and compromising the web server?

Respuesta: 198.51.100.55

client_ip

1 Value, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%
198.51.100.55	7,876	100%

Which day was the peak traffic in the logs? (Format: YYYY-MM-DD)

Respuesta: 2025-10-12

New Search

1 index=main sourcetype=web_traffic | timechart span=1d count | sort by count | reverse

✓ 17,172 events (before 12/3/25 10:02:17.000 PM) No Event Sampling

Events (17,172) Patterns Statistics (20) Visualization

100 Per Page Format Preview

_time

2025-10-12

2025-10-10

2025-10-14

2025-10-11

2025-10-13

2025-10-17

2025-10-19

2025-10-01

2025-10-15

2025-10-04

2025-10-07

2025-10-16

2025-10-03

2025-10-09

2025-10-08

2025-10-05

2025-10-02

2025-10-18

2025-10-06

What is the count of Havij user_agent events found in the logs?

Respuesta: 993

1

index=main sourcetype=web_traffic | timechart span=1d count

✓ 17,172 events (before 12/3/25 11:56:39.000 PM)

No Event Sampling ▼

Events (17,172)

Patterns

Statistics (20)

Visualization

Format Timeline ▼

– Zoom Out

+ Zoom to Selection

× Deselect

< Hide Fields

≡ All Fields

SELECTED FIELDS

a host 1

a source 1

a sourcetype 1

INTERESTING FIELDS

a client_ip 100+

date_hour 24

date_mday 20

date_minute 60

a date_month 1

date_second 60

a date_wday 7

date_year 1

a date_zone 1

a domain 1

a index 1

linecount 1

a method 2

a path 23

a punct 88

a referer 1

size_bytes 100+

a splunk_server 1

status 7

a time 100+

timeendpos 1

timestartpos 1

a user_agent 11

List ▼

✍ Format

20 Per Page ▼

i

Time

Event

user_agent

✕

11 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

Count

%

Mozilla/5.0 (iPhone; CPU iPhone OS 17_5 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Mobile/15E148 Safari/604.1

3,160

18.402%

Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36

3,075

17.907%

Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.4 Safari/605.1.15

3,061

17.826%

Wget/1.21.4

1,240

7.221%

zgrab/0.x

1,238

7.209%

curl/7.88.1

1,220

7.104%

Go-http-client/1.1

1,201

6.994%

Havij/1.17 (Automated SQL Injection)

993

5.783%

sqlmap/1.7.9#stable (http://sqlmap.org)

967

5.631%

python-requests/2.28.1

510

2.97%

How many path traversal attempts to access sensitive files on the server were observed?

Respuesta: 658

path

✕

23 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

Count

%

/index.html

1,581

9.207%

/blog

1,567

9.125%

/

1,565

9.114%

/static/app.css

1,532

8.922%

/shop

1,526

8.886%

/contact

1,525

8.881%

/search?q=test

666

3.878%

/item.php?id=1

661

3.849%

/item.php?id=1 AND SLEEP(5)--

660

3.843%

/download?file=../../etc/passwd

658

3.832%

Examine the firewall logs. How many bytes were transferred to the C2 server IP from the compromised web server?

Respuesta: 126167

New Search

Save As ▼

Create Table View

Close

1

sourcetype=firewall_logs src_ip="10.10.1.5" AND dest_ip="198.51.100.53" AND action="ALLOWED" | stats sum(bytes_transferred) by src_ip

All time ▼

🔍

✓ 285 events (before 12/3/25 11:52:27.000 PM)

No Event Sampling ▼

Job ▼

||

🗨 Verbose Mode ▼

Events (285)

Patterns

Statistics (1)

Visualization

100 Per Page ▼

✍ Format

Preview ▼

src_ip ↕

sum(bytes_transferred) ↕

10.10.1.5

126167

If you enjoyed today's room, check out the [Incident Handling With Splunk](#) room to learn more about analyzing logs with Splunk.

No requiere respuesta